

Architecture.md v1.1

Chapter 9 — Security, Permissions & Human Approval System

This chapter defines the security model of AI OS. Every component, service, and worker agent must follow these rules. Security is enforced by architecture, not by individual agents.

9.1 Security Philosophy

AI OS follows the principle of **Least Privilege**.

Every component receives only the minimum permissions required to complete its assigned task.

Permissions are **granted**, never assumed.

9.2 Security Objectives

The system shall:

- Protect user data.
 - Prevent unauthorized actions.
 - Require user approval for sensitive operations.
 - Secure credentials and secrets.
 - Maintain a complete audit trail.
 - Isolate agent permissions.
-

9.3 Security Layers

AI OS security consists of five layers.

Layer 1 — User Authentication

Future support for:

- Password
- PIN

- Biometrics
- Hardware Security Keys

Version 0.1:

Local user authentication only.

Layer 2 — Permission Service

Centralized permission verification.

Every request requiring privileged actions passes through this service.

Layer 3 — Human Approval System

Protects high-risk operations.

Layer 4 — Data Protection

Encryption of sensitive information.

Layer 5 — Audit Logging

Every sensitive action is permanently logged.

9.4 Permission Model

Permissions are assigned per agent.

Example:

Analytics Agent

Allowed:

- Read analytics
- Read project memory

Denied:

- Delete files
- Execute trading
- Modify system settings

Permissions are defined centrally, not inside agent logic.

9.5 Permission Categories

Read

Examples:

- Read memory
 - Read files
 - Read calendar
-

Write

Examples:

- Update tasks
 - Save notes
 - Store memories
-

Execute

Examples:

- Launch application
 - Run workflow
 - Generate report
-

Administrative

Examples:

- Delete memory
- Modify configuration
- Install plugins

Administrative permissions require explicit authorization.

9.6 Human Approval System

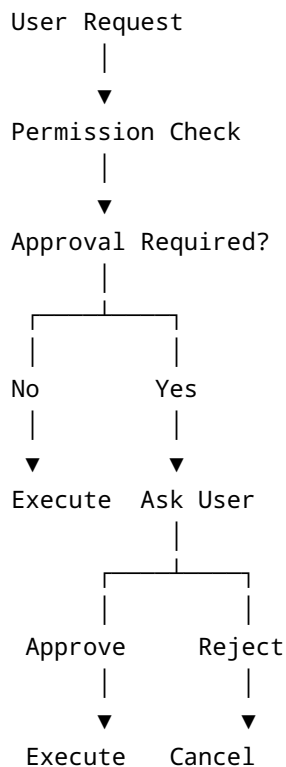
Certain actions cannot be executed automatically.

Examples include:

- File deletion
- Permanent memory deletion
- Executing trades
- Sending emails
- System shutdown
- Modifying security settings
- Installing or removing plugins

These actions require user approval.

9.7 Approval Workflow



No agent may bypass this workflow.

9.8 Approval States

Every approval request has one state.

- PENDING
- APPROVED
- REJECTED
- EXPIRED
- CANCELLED

Only the Approval Service may change these states.

9.9 Permission Enforcement

Before every privileged action:

1. Validate request.
2. Verify permissions.
3. Determine approval requirement.
4. Execute or reject.

Permission checks occur **before** execution.

9.10 Secrets Management

Sensitive information shall never be stored inside source code.

Examples:

- API Keys
- Authentication Tokens
- Database Credentials
- Encryption Keys

Version 0.1:

Stored in:

- `.env`

- Secure local configuration

Future versions may integrate external secret managers.

9.11 Encryption Policy

The following data must be encrypted at rest:

- Credentials
- Tokens
- Financial information
- Sensitive personal data

Non-sensitive metadata may remain unencrypted if appropriate.

9.12 File System Protection

The PC Control Agent must never perform destructive file operations without approval.

Protected actions include:

- Delete
- Move
- Rename
- Overwrite
- Format

Read-only operations do not require approval unless configured otherwise.

9.13 Browser Security

The Browser Agent may:

- Open websites
- Search the web
- Read publicly accessible content

It must not:

- Submit forms
- Complete purchases
- Enter credentials

- Perform account actions

without explicit approval.

9.14 Trading Security

The Trading Agent may:

- Analyze markets
- Generate insights
- Track portfolios
- Calculate risk

It must not:

- Place orders
- Buy or sell assets
- Connect to brokerage APIs for execution

without user approval.

9.15 Email Security

The Email Agent may:

- Read emails
- Categorize messages
- Draft replies

It must not send emails until the user approves the final draft.

9.16 Memory Protection

Long-term memory operations requiring approval:

- Permanent deletion
- Bulk modification
- Export of sensitive memories

Normal reads and updates follow standard permissions.

9.17 Audit Logging

Every privileged action generates an immutable audit record.

Audit records include:

- Timestamp
- User
- Agent
- Action
- Approval Status
- Result
- Request ID

Audit logs are never editable.

9.18 Failed Security Events

Examples:

- Permission denied
- Invalid credentials
- Unauthorized access
- Approval timeout

Each event is:

- Logged
- Assigned a severity
- Returned as a structured error

The system must continue operating safely.

9.19 Security Rules

Every module must satisfy:

- Least Privilege
- Explicit Permission Checks
- Human Approval for Sensitive Actions
- Centralized Secret Storage
- Encryption of Sensitive Data
- Immutable Audit Logs

Violation of these rules is considered an architectural failure.

9.20 Future Expansion

Future versions may introduce:

- Multi-user roles
- Hardware security modules
- Biometric authentication
- Trusted devices
- Fine-grained permission policies
- Zero-trust networking
- Security analytics dashboard

These additions must remain compatible with the centralized Permission Service and Human Approval System.

End of Chapter 9

Next Chapter: Chapter 10 — Logging, Monitoring & Observability